IT 490 CAPSTONE | WEEK 4 | PALO ALTO NETWORKS

Palo Alto Firewall Basic Setup

Blocking a reported probe source, denying unused services, and restricting client DNS to approved domain controllers.

/32	6	9	8
PROBE SOURCE BLOCKED	ORDERED SECURITY RULES	SETUP STEPS	VALIDATION TESTS

PURPOSE

This report defines a firewall baseline for Company ABC. The policy blocks traffic sourced from 58.218.199.147 and permits DNS requests from LAN clients only to DC1 and DC2. An explicit final drop rule closes services that have no approved exception.

SCOPE OF THE EXAMPLE

The assignment provides the reported source and the two domain controller addresses. Other addressing and topology details are design assumptions. No firewall exports, packet captures, or test results were supplied, so the validation section states expected results rather than claiming a completed deployment.

REPORT DETAILS

Prepared by	Justin Martin
Date	October 12, 2026
Platform assumption	Palo Alto PA 440 using the PAN OS web interface
Assignment	Basic firewall setup with an example
Report status	Scenario configuration and validation plan

01 Design and Addressing

SECURITY OBJECTIVES

Block the reported source across all applications and services. Keep required DNS available to the two approved servers. Allow other services only after a specific business requirement defines the source, destination, application, and port.

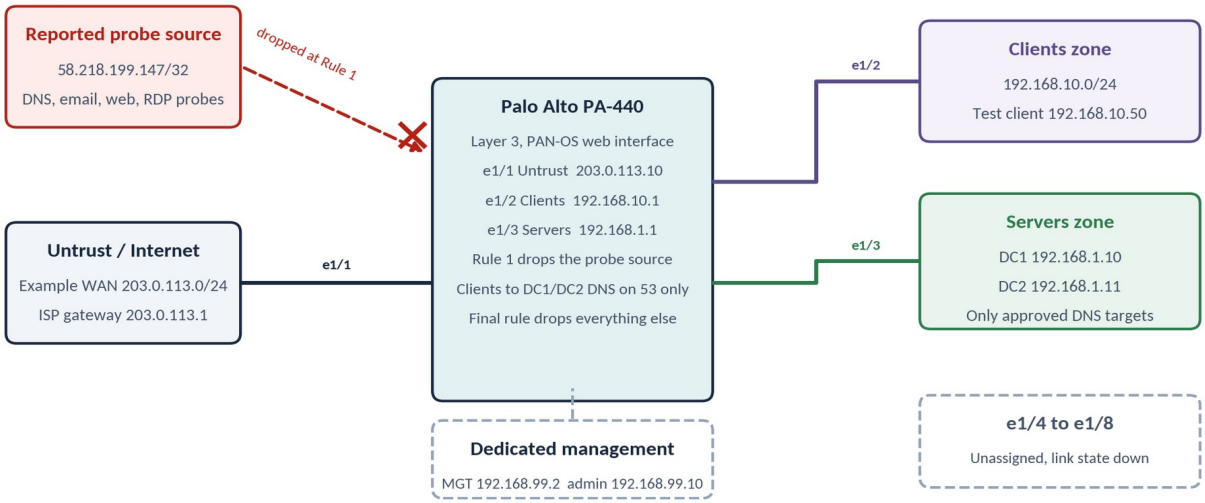


Figure 1.1 — *Proposed routing layout. Original diagram for this scenario. The dedicated management network is separate from the data interfaces.*

Interface or host	Zone or role	Example address
ethernet1/1	Untrust	`203.0.113.10/24`
ethernet1/2	Clients	`192.168.10.1/24`
ethernet1/3	Servers	`192.168.1.1/24`
DC1 and DC2	Approved DNS servers	`192.168.1.10` and `192.168.1.11`
MGT and administrator	Dedicated management	`192.168.99.2` and `192.168.99.10`
LAN test client	Clients	`192.168.10.50/24`

The WAN address is a documentation example. The ISP gateway is assumed to be 203.0.113.1. Clients use 192.168.10.1 as their gateway, and the servers use 192.168.1.1.

TRAFFIC MUST REACH THE FIREWALL

The separate client and server segments force client DNS to the domain controllers through the firewall. A switch or router must not provide a bypass route. Traffic that stays within one subnet needs endpoint firewall rules or switch isolation because a routed firewall cannot inspect traffic it never receives. [2]

02 Initial Setup and Objects

1 Secure the management interface

Connect directly to MGT and use https://192.168.1.1 with the initial admin credentials. Change the password immediately and create named administrator accounts. Under **Device > Setup > Interfaces**, move MGT to `192.168.99.2/24` and permit administration only from `192.168.99.10`. Enable HTTPS and SSH as needed. Disable HTTP and Telnet. [1]

Keep MGT disconnected from the production server network during initialization. Its factory address overlaps the proposed server gateway. Management routing and upstream access controls must separately limit administrative traffic and DNS to the approved servers.

2 Prepare the platform

Register the firewall, verify applicable licenses, and install a supported vendor recommended software release for the actual appliance. Update application content and save a baseline configuration under **Device > Setup > Operations**. The example uses local PAN OS menus rather than cloud management.

3 Create interfaces and routing

Under **Network > Zones**, create Layer 3 zones named Untrust, Clients, and Servers. Under **Network > Interfaces > Ethernet**, assign the three data interfaces their addresses and zones. Add them to the same virtual router, then configure a default route of `0.0.0.0/0` through ethernet1/1 to `203.0.113.1`. [2]

Connected routes cover the two internal networks. Internet access still requires an approved Security rule and, for private client addresses, an appropriate source NAT rule. This baseline does not introduce a blanket internet allow rule.

4 Build reusable objects

Under **Objects > Addresses**, create `Probe_Source` as `58.218.199.147/32`, `LAN_Clients` as `192.168.10.0/24`, `DC1` as `192.168.1.10/32`, and `DC2` as `192.168.1.11/32`. Under **Objects > Address Groups**, add DC1 and DC2 to `Approved_DNS`.

Under **Objects > Services**, create `DNS_TCP_53` and `DNS_UDP_53` with destination port 53. Leave source ports unrestricted because client requests use ephemeral source ports. Combine them in `DNS_53`. Create `TCP_853` and `UDP_853`, then group them as `Encrypted_DNS_853`. [4]

03 Ordered Security Policy

Add rules under **Policies > Security** in the following order. Every rule uses Log at Session End. PAN OS applies the first matching rule and permits return traffic for an allowed session, so DNS replies do not need a broad reverse allow rule. [3]

#	Rule name	Match criteria	Action
1	Block_Probe_Source	From any zone to any zone. Source Probe_Source. Destination any. Application any. Service any.	Drop
2	Allow_Client_DNS	From Clients to Servers. Source LAN_Clients. Destination Approved_DNS. Application dns. Service DNS_53.	Allow
3	Block_Other_DNS_53	From any zone to any zone. Source and destination any. Application any. Service DNS_53.	Drop
4	Block_Encrypted_DNS_853	From any zone to any zone. Source and destination any. Application any. Service Encrypted_DNS_853.	Drop
5	Block_Encrypted_DNS	From any zone to any zone. Source and destination any. Applications dns-over-https and dns-over-tls. Service any.	Drop
6	Deny_Unapproved	From any zone to any zone. Source, destination, application, and service any.	Drop

THE SOURCE BLOCK TAKES PRIORITY

Rule 1 drops all matching traffic from the reported address, including probes on DNS, email, web, remote desktop, or unexpected ports. It does not depend on identifying a specific application. The assignment identifies this source as offending. The report does not independently attribute its owner or claim a confirmed compromise.

UNUSED SERVICES REMAIN DENIED

Place any future approved business allow rules above Deny_Unapproved and below the DNS restrictions. Remove broad sample allow rules. The explicit final drop rule also catches traffic that would otherwise reach the built in intrazone allow rule. Unused TCP and UDP services, including email and remote desktop, receive no exception in this baseline. [3]

04 DNS Restrictions and Port Lockdown

5 Assign approved DNS servers

Set DHCP DNS options, or managed static client settings, to `192.168.1.10` and `192.168.1.11`. Client configuration supports the policy, but the firewall restriction is what blocks direct requests to other resolvers.

6 Preserve DNS over both transports

Allow the dns application to Approved_DNS through DNS_53. This explicitly covers TCP and UDP port 53. Rule 3 then drops remaining port 53 sessions regardless of the detected application, including unauthorized requests to public or alternate internal resolvers.

The baseline grants no external DNS forwarding exception to DC1 or DC2. Internal name resolution can use records those servers host. If external resolution is required, separately approve specific forwarders and document that change in scope rather than allowing arbitrary outbound DNS.

7 Address encrypted DNS and local bypasses

Port 853 restrictions cover typical DNS over TLS and DNS over QUIC. The encrypted DNS application rule adds another layer where App ID identifies the traffic. Broad HTTPS access is absent from this baseline. If it is later added, browser and operating system policy must disable unauthorized secure DNS, with resolver blocking and approved decryption where appropriate. A port 53 rule alone does not control DNS hidden inside HTTPS. [5]

Require endpoint or switch controls to prevent clients from using a rogue resolver on their own subnet. Apply equivalent controls to IPv6 before enabling it. This example does not configure IPv6 routing.

8 Disable unused physical and management services

Leave ethernet1/4 through ethernet1/8 unassigned and disconnected. Set their Link State to down in the interface advanced link settings where available. Keep management profiles off Untrust and other data interfaces unless a restricted administrative requirement justifies them. [2]

Port lockdown has two parts: disabling unused physical connections and denying unapproved network services. Neither replaces the other.

05 Commit and Validation

9 Validate and activate the candidate configuration

Save a named backup. Use **Commit > Validate Commit** and resolve errors, shadowed rules, and application dependency warnings. Review rule order, then commit and verify completion. A successful commit confirms configuration acceptance, not successful traffic enforcement. [6]

Review existing sessions from the reported source and clear matching sessions if needed. This avoids relying on a new policy alone to terminate an existing session. [7]

PAN-OS CLI

```
clear session all filter source 58.218.199.147
```

Test	Expected result	Evidence to retain
Source 58.218.199.147 to any service	Block_Probe_Source and drop	Policy match plus observed traffic log
Client to DC1 and DC2, UDP 53	Allow_Client_DNS and successful query	Query output and allow log
Client to DC1 and DC2, TCP 53	Allow_Client_DNS and successful query	TCP query output and allow log
Client to 8.8.8.8, TCP or UDP 53	Block_Other_DNS_53 and drop	Timeout or failure plus drop log
Client to another internal resolver	Drop at firewall, or local endpoint control	Relevant firewall or endpoint log
Client to TCP or UDP 853	Block_Encrypted_DNS_853 and drop	Drop log
Unapproved web, email, or RDP session	Deny_Unapproved and drop	Drop log
Unused physical interface	No active link or assigned network	Interface status

POLICY CHECKS AND LIVE TESTS

Use test security-policy-match to inspect expected rule selection. Repeat with DC2 and protocol 6 for TCP. [8]

PAN-OS CLI

```
test security-policy-match from Clients to Servers source 192.168.10.50
  destination 192.168.1.10 destination-port 53 protocol 17 application dns
```

From an authorized Linux test client, compare a UDP and a TCP query against each domain controller. Use a known record hosted by the domain controllers. Repeat for DC2 and a prohibited resolver.

LINUX TEST CLIENT

```
dig @192.168.1.10 abc.example
dig +tcp @192.168.1.10 abc.example
```

Inspect **Monitor > Logs > Traffic** for the source, destination, port, rule, and action. No results are recorded here because these tests have not been executed.

06 Security Analysis and Reflection

REQUIREMENT COVERAGE

Requirement	Configuration response
Block the reported source	First rule uses the exact /32 source with any application and service.
Lock down unused ports	Explicit final drop policy, restricted administration, and disabled unused links.
DNS only to DC1 and DC2	Approved server group, dns application, TCP and UDP 53 service group, and later DNS drop rules.

OPERATIONAL BOUNDARIES

This baseline addresses the assignment requirements. Domain logon, directory replication, DHCP relay, time synchronization, web access, and remote administration require their own documented rules if Company ABC needs them. DNS permission alone does not provide complete Active Directory connectivity.

Firewall policy covers traffic crossing the data plane. MGT access and locally originated management services need their own configuration and upstream controls. Same subnet communication needs endpoint or switch enforcement. These boundaries determine whether the intended restrictions hold across the environment.

ACCEPTANCE CRITERIA

The deployment is ready for acceptance when both approved DNS servers answer authorized client requests over TCP and UDP, unauthorized resolver tests fail, the reported source matches the top drop rule, and unapproved services remain blocked. Retain the committed configuration and corresponding logs. Verify separately that required business services and administrator access still work.

PROFESSIONAL REFLECTION

What stood out to me was the difference between writing a rule and making sure traffic actually reaches it. A DNS restriction can look correct while clients still use a resolver on their own subnet. Separating the networks and accounting for endpoint behavior makes the design more complete.

I also treated the reported source block as one control within the broader baseline. The default drop policy limits exposure even when a probe arrives from a different address. Clear rule order and a focused test plan make the configuration easier to explain, maintain, and verify.

References

[1] Palo Alto Networks. (n.d.). *Perform the initial configuration for a NGFW*. https://docs.paloaltonetworks.com/ngfw/getting-started/set-up-your-ngfws/perform-the-initial-configuration-for-a-ngfw

[2] Palo Alto Networks. (n.d.). *Configure Layer 3 interfaces*. https://docs.paloaltonetworks.com/ngfw/networking/configure-interfaces/layer-3-interfaces/configure-layer-3-interfaces

[3] Palo Alto Networks. (n.d.). *Security policy*. https://docs.paloaltonetworks.com/pan-os/11-1/pan-os-admin/policy/security-policy

[4] Palo Alto Networks. (n.d.). *Policy object: Services*. https://docs.paloaltonetworks.com/network-security/security-policy/administration/objects/services

[5] Palo Alto Networks. (n.d.). *Configure DNS Security over DoH*. https://docs.paloaltonetworks.com/dns-security/administration/configure-dns-security/configure-dns-over-doh

[6] Palo Alto Networks. (n.d.). *Commit changes*. https://docs.paloaltonetworks.com/ngfw/help/11-2/web-interface-basics/commit-changes

[7] Palo Alto Networks. (n.d.). *End a single session DoS attack*. https://docs.paloaltonetworks.com/ngfw/administration/zone-protection-and-dos-protection/dos-protection-against-flooding-of-new-sessions/end-a-single-session-dos-attack

[8] Palo Alto Networks. (n.d.). *Test the configuration*. https://docs.paloaltonetworks.com/ngfw/pan-os-cli-quick-start/use-the-cli/test-the-configuration

Source labels link the walkthrough to the reference entries above. Figure 1.1 is an original scenario diagram. No external screenshots or simulated evidence are included.